

K-Waay 批处理接纳中参与方区分条件的形式化分析

匿名作者

摘要

K-Waay 的 `BatchReceive` 构造规定，同一次调用中的不同输入应分别对应不同参与方。为考察这一条件在批处理接纳边界上的语义作用，本文对三个共享发送来源与顺序处理生命周期的固定两槽 Tamarin 符号模型进行受控比较，分别研究宽松接纳、消息级限制和参与方级限制。已有执行记录及后续独立复跑表明：在宽松接纳下，一个匹配的发送来源可支持同一批次上下文中的两个接收事件；消息级限制虽能保持消息区分和作用域内的来源单射性，同一参与方产生的两条不同消息仍可被共同接纳；参与方级限制直接约束所收集条目的参与方坐标，在模型接收事件边界上保持参与方区分，同时保留可达的有效参与方批次。该比较说明，消息区分和发送实例区分不能替代批内参与方区分，批次组合边界需要显式维护参与方关系。分析以批次组合可控、新鲜符号消息和理想化精确来源匹配为前提，结论止于固定两槽模型中的 `ReceiverAccept` 事件，不构成对完整 K-Waay 执行的精化定理，也不表示密码原语被攻破或真实部署存在漏洞。后续独立复跑保留了证明器输出和导出轨迹，但并非对历史执行记录的恢复。

0 引言

单个协议输入所满足的安全性质，并不能单独确定多个输入以何种方式组合到一次协议操作中仍然安全。当接收方把若干与发送方相关联的输入归入同一处理过程时，即使每个条目都有合法来源，整个集合仍可能重复出现接口原本只允许一次的参与方。安全消息系统中的会话处理研究表明，组合边界需要与其组成元素分别考察 [3]。本文关注的并非跨会话或跨会话群组的组合，而是一次接收方批处理内部的输入关系。

K-Waay 是一种后量子、类似 X3DH 且具有可否认性的认证密钥交换协议 [1]。其 `BatchReceive` 操作在接收方状态下成组处理多个输入；完整构造明确规定，同一次调用中的各元素应对应不同参与方 [2, 第 5.1 节, 第 21 页]。这一条件已经存在于源协议。本文所考察的是它维护了何种关系，以及作用于其他坐标的限制能否维护同一关系。下文将该批内关系记为 `DISTINCTPARTYPERBATCH`；这一分析性名称由本文引入，并不表示 K-Waay 遗漏了新的协议条件。

区别这些坐标具有直接意义。同一建模参与方可以在不同发送实例中产生两条消息。由这两个条目组成的批次可以同时满足消息不同、任一精确来源均未被重复接受，却仍在参与方层面出现两次。反过来，把同一个精确条目放入两个槽位，则引出的是接受多重性问题。因而，在判断某项接纳限制能否达到目标之前，必须区分参与方身份、消息身份以及发送实例 (occurrence) 匹配。身份概念与单射对应关系已有系统研究 [5, 4]，本文关注的是这些关系在 K-Waay 批处理接口上的相互作用。

研究问题与方法。 围绕上述边界，第1节提出三个问题：放宽不同参与方条件后，哪些参与方重复组合变为可达 (RQ1)；在该抽象下，一个匹配的发送来源能否支持同一批次中的多个接收事件 (RQ2)；仅约束消息坐标是否足以推出批内参与方区分 (RQ3)。分析比较三个固定两槽 Tamarin 模型 [6]：宽松接纳模型、消息级限制模型和参与方级限制模型。三者共享发送生成、输入收集、精确来源匹

配及顺序处理生命周期，仅在接纳谓词及相应拒绝分支上约束不同坐标。参与方级模型充当正控制，用于直接检验目标关系，并不预设直接比较参与方身份是维护该关系的唯一实现方式。

结果与贡献。 本文的贡献在于形式化阐明原协议所述条件的语义作用，并在明确的建模假设下分离消息级、发送实例级和参与方级性质。宽松接纳模型存在一条执行：一个匹配的 `Send` 来源在同一批次上下文中支持两个 `ReceiverAccept` 事件。消息级模型能够保持消息区分和作用域内的精确来源单射性，却仍可共同接纳来自同一参与方的两条不同消息。参与方级模型直接约束所收集条目的参与方坐标；已有结果既确认接收事件之间的参与方区分，也给出可达的有效参与方批次。其中，消息级结果给出了核心分离：消息区分和作用域内的单射性成立，并不蕴含批内参与方区分。

研究边界。 分析假定对手在建模边界上能够控制候选条目的批次组合，但不据此认定网络攻击者能够控制真实部署中的批次构造器。新鲜符号消息和发送实例坐标、理想化的持久来源关系以及模型局部的接收事件，使三个模型之间的比较保持简洁、可解释。当前工作给出源接口到抽象对象的映射，但没有建立完整 K-Waay 执行到模型的精化定理；其结果既不是密码学攻击或部署漏洞，也不是针对任意批大小的机器证明。论文使用既有模型执行记录，2026 年 9 月 16 日完成的独立复跑又保存了精确命令、输入哈希、证明器标准输出与错误输出以及导出轨迹；该复跑验证了当前抽象结果的可复现性，但不恢复历史运行的出处，也不扩展研究结论。

第1节介绍协议接口及身份区分问题，第2节定义分析目标和对手边界。后续第 3、4 节分别给出形式化抽象与机器分析，第 5、6 节讨论设计含义、局限和相关工作，第 7 节总结全文。

1 K-Waay BatchReceive 与参与方区分问题

1.1 K-Waay 与 BatchReceive

K-Waay 是一种由 KEM、数字签名和 split-KEM 构造的后量子、类似 X3DH 的可否认认证密钥交换协议 [1]。完整协议包含远多于本文问题所需的密码结构。这里仅考察接收方在一次协议操作中处理多个发送方关联输入的接口，即 `BatchReceive`。

在协议接口中，发送方以自身本地状态和接收方预密钥束为输入调用 `Send`，得到会话密钥与协议消息。接收方临时密钥材料被复用时，多条发送方消息可能对应同一接收方临时状态。接收方随后针对该状态，以输入向量调用 `BatchReceive` [2, 第 4.1 节]。将该向量写为

$$S = ((pk_{j_1}, prek_{j_1}, m_{j_1}), \dots, (pk_{j_d}, prek_{j_d}, m_{j_d})), \quad d \geq 1, \quad (1)$$

其中，每个分量包含所声称发送方的公钥、该发送方的预密钥束以及相应协议消息。`BatchReceive` 针对各分量验证相关预密钥信息，并利用接收方的长期与临时秘密材料执行所需的解封装操作。若 split-KEM 解封装失败，协议通过返回全为 $\perp$ 的结果向量拒绝整个批次；否则返回对应的派生密钥结果向量，其中个别元素仍可能为 $\perp$ [2, 第 5.1 节，图 10]。

上述描述无意复述完整握手或其计算安全证明，而是确定本文关心的协议对象：一次接收方调用可以在共享接收方状态下处理多个与发送方相关联的分量。

这种成组处理使分量之间的关系成为执行语义的一部分。每个位置都关联一个所声称的发送方、一条消息和一个接收方密钥结果。本文关注的是这些分量作为一个整体被视为可接纳批次的边界，并将其称为批处理接纳 (batch admission)。该术语仅用于分析，不表示原始 K-Waay 规范中另有一个独立算法。

1.2 原协议中的不同参与方条件

K-Waay 完整构造明确指出：对于给定的 `BatchReceive` 调用， S 中的每个元素均假定对应不同参与方 [2, 第 5.1 节, 第 21 页, 图 10 之后]。该条件的作用域是单个批次，约束一次 `BatchReceive` 调用中各分量之间的关系；它不要求某一参与方在整个协议中只出现一次、只运行一个会话或只产生一条协议消息。

下文将这一条件记为 `DISTINCTPARTYPERBATCH`。原论文以自然语言陈述该条件，本文仅为便于分析而命名。它规定批内参与方关系，但没有限定具体执行机制：原陈述并未说明应由客户端、服务器、调用者还是其他批次构造组件完成检查，也不能据此推断某个真实实现必然缺少相应检查。第2节将形式化定义该关系，并给出研究所采用的对手与证据边界。

1.3 身份坐标

为区分参与方级条件与其他唯一性形式，将批处理接纳所需的信息抽象为条目

$$E_i = (A_i, oid_i, m_i), \quad (2)$$

其中， A_i 表示建模的协议参与方， oid_i 表示分析中的发送实例坐标， m_i 表示发送方产生的协议内容。英文母稿和 Tamarin 源模型将该实例坐标记为 sid_{model} ；为避免与 K-Waay 协议消息摘要中的 transcript sid 混淆，中文叙述统一采用 $oid \equiv sid_{model}$ 。这只是论文记号的替换，不改变源模型变量、规则或事件。式(2)是分析抽象，而非 K-Waay 输入在线路上的编码形式。

A_i 同样不应被解释为账户记录、公钥字节串、预密钥或实现对象；它表示不同参与方条件所作用的协议主体坐标。与批处理接纳有关的坐标及其语义边界列于表1。

表 1: 批处理接纳中的身份坐标

坐标	区分对象	解释边界
参与方 A	建模的协议主体	不等同于预密钥或密钥编码
消息 m	发送方产生的协议内容	消息不同不要求来源参与方不同
发送实例 oid	分析中的一次发送方会话或出现	实例不同不要求参与方不同
槽位 i	同一批次中的一个位置	位置不同不要求参与方或消息不同
批次 B	一次成组的接收方执行	不要求其中的参与方在全局唯一
接收方状态 r	成组执行所共享的接收方状态	该坐标不能确定参与方的身份或数量

表1区分的是概念角色，并不声称原型中任意坐标等式组合都可实现。后续形式模型为每次发送实例新鲜生成 oid 和 m ；在此假设下，来自不同参与方的合法来源元组也具有不同的实例与消息坐标。反向推理并不成立：同一参与方可以经由多个协议实例产生不同消息。因此，

$$A_i = A_j \quad \text{可与} \quad oid_i \neq oid_j \wedge m_i \neq m_j \quad \text{同时成立。} \quad (3)$$

类似地， $i \neq j$ 只表明两个分量位于不同批次位置，不能推出 $A_i \neq A_j$ ；批次标识和接收方状态只确定共同处理上下文，也不能确定其中包含多少个不同参与方。

这些区别也影响认证证据的解释。若证据把某个协议分量绑定到参与方 A ，它可以确定该分量的来源，却不能单独证明 A 在整个批次中至多出现一次。相应地，两条消息不相等只能区分协议内容，不能推出其来源参与方坐标不相等。

1.4 动机中的参与方重复组合

考虑如下两位置候选批次：

$$B^* = ((A, oid_1, m_1), (A, oid_2, m_2)), \quad oid_1 \neq oid_2, \quad m_1 \neq m_2. \quad (4)$$

两个分量位于不同槽位，来自不同建模发送实例，并包含不同消息，但其参与方坐标均为 A 。因此，仅排除重复消息的限制不能凭 $m_1 \neq m_2$ 排除这一组合；不同参与方条件则因两个条目的参与方坐标相同而排除它。

该例揭示如下逻辑不蕴含关系：

$$m_1 \neq m_2 \not\Rightarrow \text{party}(E_1) \neq \text{party}(E_2). \quad (5)$$

式(4)只是引出形式化问题的分析对象，并非机器检查得到的攻击轨迹；它也不属于满足 K-Waay 原有不同参与方条件的执行域。该例所要分离的是不同身份坐标上约束的作用：放宽参与方关系后会出现何种变化，以及其他坐标上的限制能否替代该关系。

1.5 研究问题

上述坐标区分产生三个研究问题。

RQ1: 放宽不变量。 在其他接纳行为保持可比的前提下，移除 DISTINCTPARTYPERBATCH 要求后，哪些批内参与方重复组合变为可达？

RQ2: 分量级后果。 在形式模型采用的接收侧抽象中，放宽不同参与方条件是否会使一个匹配的发送来源支持同一批次中的多个接收事件？这里的“接收分量”是符号抽象中的事件，不等同于 K-Waay 原安全模型为接收方会话给出的单一接受或拒绝状态。

RQ3: 坐标替代。 在当前建模生命周期下，仅作用于消息身份的限制能否推出原有的批内参与方区分目标，抑或消息不同的分量仍可具有相同的参与方坐标？

后文采用的显式参与方坐标限制是针对目标关系的正控制，而非第四个未知问题；消息坐标限制才用于检验坐标替代是否成立。以上问题区分参与方级目标与观察其后果所需的分量级行为，不预设 K-Waay 密码原语被攻破、某个部署实现存在漏洞，也不规定维护不同参与方条件的唯一机制。第2节给出相应能力、假设和非目标，后续形式化章节再说明它们在符号模型中的实现。

2 安全目标与威胁模型

2.1 批内参与方区分目标

第1节将 K-Waay 的不同参与方条件与消息、发送实例、槽位和批次坐标区分开来。现将该批内关系形式化为分析目标。设 $B = (E_1, \dots, E_n)$ 为有序批次， $\text{party}(E_i)$ 表示与条目 E_i 关联的建模协议主体，定义

$$\text{DISTINCTPARTYPERBATCH}(B) \triangleq \forall 1 \leq i < j \leq n, \text{party}(E_i) \neq \text{party}(E_j). \quad (6)$$

因此，同一已接纳批次中任意两个不同位置都必须投影到不同的建模参与方。该目标是参与方坐标上的关系，不能由比较消息内容、发送实例标识或槽位索引得到。

式(6)的作用域限于一个批次。它既不要求某一参与方在整个协议、不同批次或不同会话中只出现一次，也不要求消息或发送实例全局唯一。若某个组合不满足该式，下文仅称其违反参与方级批次不变量；这种违反本身不表示密码材料畸形、认证失败或底层密码原语被攻破。

这一不变量是对批次组成的结构谓词，而非对单个条目的密码真实性谓词。它规定哪些参与方投影可以共存于一个批次，但不把参与方投影的获取方式和检查机制写入目标本身。定义针对任意有限 n 给出，以使目标关系独立于模型界限；机器分析固定 $n = 2$ ，此时目标化为 $\text{party}(E_1) \neq \text{party}(E_2)$ 。当前证据不构成任意批大小的完整协议证明，也不预设违反该不变量必然产生接收侧可观察后果。

2.2 对手能力与批次组合边界

威胁模型采用符号批次组合对手 (symbolic batch-composition adversary)。标准 Dolev-Yao 网络能力使对手能够获知、保留、重放并重新组合网络上暴露的符号项；在此基础上，模型另行假定对手能够在候选发送方条目已经可用之后，选择条目、安排其槽位，并把所得组合提交给接纳步骤。该能力位于候选条目可用性与批次接纳决定之间，只涉及输入组合，不授予对手创建诚实参与方内部状态的能力。

这一组合能力是一项分析假设，不能直接解释为真实网络对手已经控制部署中的批次构造器。具体系统可能由客户端、服务器、调用者或其他组件构造批次；若要把模型能力提升为部署结论，还需说明相应接口、缓冲与调度机制。本文没有提供这种实现层证据。

威胁模型区分两类重复输入。第一类是把同一暴露元组提交两次，即 $E_1 = E_2$ 。第二类是选取两个不同的发送来源元组

$$E_1 = (A, oid_1, m_1), \quad E_2 = (A, oid_2, m_2), \quad E_1 \neq E_2, \quad (7)$$

但二者具有相同的参与方投影 A 。在原型的新鲜值假设下，第二类元组的发送实例与消息坐标均不同。这里所需的是批次组合能力，而非身份伪造：对手无需冒充或虚构另一个建模参与方。

对于涉及已接收分量的结论，发送方与接收方之间的匹配作用于完整建模来源元组 (A, oid, m) ，而非仅作用于 A 。对手可以在语法上重组从网络获知的值，但只有该完整元组确由建模发送生命周期产生时，重组结果才具有匹配来源；参与方坐标相等本身不提供来源证据。所分析的组合也不依赖密钥恢复、KEM 或签名机制被攻破，亦不依赖伪造模型省略的密码材料。这些排除项只界定抽象范围，并不构成对被省略机制的安全证明。

2.3 建模假设

每次建模的发送发生均新鲜生成发送实例坐标 oid 和消息 m 。因此，两个不同的诚实发送来源在模型中具有不同的实例和消息坐标；同一参与方仍可触发多个发送发生。新鲜性用于控制三个模型的共同生命周期，不应被解释为真实协议消息不存在碰撞、重传或复用行为的独立结论。

来源匹配采用理想化精确关系：ReceiverAccept 与先前的发送来源按完整 (A, oid, m) 元组对应。仅有 A 相同不足以建立来源，来源元组中的值被重新拼接也不足以得到匹配。该假设使分析能够分离批次组合与来源伪造，但没有建模 K-Waay 中实现这一关联所需的全部密码计算。

机器模型固定为两个槽位，并以顺序生命周期处理已接纳分量。相关事件还被限定在同一批次标识和接收方上下文 (bid, rst) 内；性质不跨批次推断全局唯一性。两槽约束是验证边界，而非式(6)的定义边界。模型比较由此针对相同的发送、收集、来源匹配和处理骨架，只改变接纳谓词所约束的身份坐标。

2.4 证据边界与非目标

直接形式化对象包括产生来源元组所需的发送生命周期、符号网络上的批次组合、批次接纳或拒绝、发送来源关系以及分量级 `ReceiverAccept` 事件。`ReceiverAccept` 是批处理接纳抽象中的模型局部事件，并非 K-Waay 原安全模型定义的协议级接受事件；引入该事件本身不预设任何验证结果。

机器检查证据止于 `ReceiverAccept`。当前模型没有展开完整的 KEM、数字签名和 KDF 计算，也没有妥协行为、棘轮状态、下游密钥接口或应用消费者；模型中不存在正式的 `KEY` 或 `TEST` 对象，不输出供上层使用的会话密钥，也不包含应用状态安装事件。因此，结果不直接建立机密性、密钥不可区分性、完整协议认证失败或重复安装后果。

将接收事件连接到上层状态需要额外的组合假设，本文不作此断言。当前工作同样没有给出从完整 K-Waay 执行到抽象模型的精化定理，没有验证任意有限批大小，也不评价某个部署实现是否可被利用。其证据范围是：在上述固定两槽、精确来源和批次上下文假设下，比较不同身份坐标上的接纳限制所保持的关系。

参考文献

- [1] Daniel Collins, Loïs Huguenin-Dumittan, Ngoc Khanh Nguyen, Nicolas Rolin, and Serge Vaude-
nay. K-Waay: Fast and deniable post-quantum X3DH without ring signatures. In *33rd USENIX
Security Symposium*, pages 433–450, 2024.
- [2] Daniel Collins, Loïs Huguenin-Dumittan, Ngoc Khanh Nguyen, Nicolas Rolin, and Serge Vau-
denay. K-Waay: Fast and deniable post-quantum X3DH without ring signatures. Cryptol-
ogy ePrint Archive, Paper 2024/120, 2024. Full version of the USENIX Security 2024 paper.
<https://eprint.iacr.org/2024/120>.
- [3] Cas Cremers, Charlie Jacomme, and Aurora Naska. Formal analysis of session-handling in
secure messaging: Lifting security from sessions to conversations. In *32nd USENIX Security
Symposium*, pages 1235–1252, 2023.
- [4] Gavin Lowe. A hierarchy of authentication specifications. In *10th IEEE Computer Security
Foundations Workshop*, pages 31–43, 1997.
- [5] Simone Lupetti, Feike W. Dillema, and Tage Stabell-Kulø. Names in cryptographic protocols. In
4th International Workshop on Security in Information Systems (WOSIS 2006), pages 185–194,
2006.
- [6] Simon Meier, Benedikt Schmidt, Cas Cremers, and David Basin. The TAMARIN prover for the
symbolic analysis of security protocols. In *CAV 2013; LNCS 8044*, pages 696–701, 2013.